



PRODUCT DESCRIPTION (PD) DEPARTMENT OF VETERANS AFFAIRS

**Office of Information & Technology (OI&T)
End User Services**

**Trellix Brand Name or Equal Compact Disc (CD) / Digital Versatile Disc (DVD)
Enterprise Encryption Software**

**Date: March 10, 2026
VA-26- 00046223
PD Version Number: 1.0**

Trellix Brand Name or Equal Compact Disc (CD) / Digital Versatile Disc (DVD)
Enterprise Encryption Software
VA-26- 00046223

CONTENTS

1.0	PRODUCT REQUIREMENTS	3
1.1	SALIENT CHARACTERISTICS - SUBSCRIPTIONS	3
1.2	PROFESSIONAL SERVICES (BASE PERIOD OPTIONAL TASK 1 – NTE 80 HOURS)	5
1.3	ADDITIONAL SUBSCRIPTIONS (OPTIONAL TASK 2).....	5
1.4	SOFTWARE SUPPORT	7
2.0	NOTICE OF THE FEDERAL ACCESSIBILITY LAW AFFECTING ALL INFORMATION AND COMMUNICATION TECHNOLOGY (ICT) PROCUREMENTS (SECTION 508).....	8
2.1	SECTION 508 – INFORMATION AND COMMUNICATION TECHNOLOGY (ICT) STANDARDS	8
2.2	COMPATABILITY WITH ASSISTIVE TECHNOLOGY	8
2.3	ACCEPTANCE AND ACCEPTANCE TESTING	9
3.0	INFORMATION TECHNOLOGY USING SUSTAINABLE PRODUCTS AND SERVICES	9
4.0	SHIPMENT OF HARDWARE OR EQUIPMENT.....	9
5.0	GENERAL REQUIREMENTS.....	9
5.1	VA TECHNICAL REFERENCE MODEL	9
5.2	ZERO TRUST – VA CRITICAL SECURITY CONTROLS	9
5.3	SOCIAL SECURITY NUMBER (SSN) REDUCTION	10
5.4	INTERNET PROTOCOL VERSION 6 (IPV6).....	10
5.5	SOFTWARE AND LICENSING REQUIREMENTS	11
5.6	TRUSTED INTERNET CONNECTION (TIC)	11
6.0	POINTS OF CONTACT	11
	ADDENDUM B – VA INFORMATION AND INFORMATION SYSTEM SECURITY/ PRIVACY LANGUAGE.....	13

Trellix Brand Name or Equal Compact Disc (CD) / Digital Versatile Disc (DVD)
Enterprise Encryption Software
VA-26- 00046223

1.0 PRODUCT REQUIREMENTS

The Department of Veterans Affairs (VA), Office of Information and Technology (OIT), End User Operations (EUO) has the need to replace an enterprise-wide deployment of Trellix ending in May 2026, which encrypts media when providing Veterans' copies of their confidential medical records. This removable media includes digital images, CDs and DVDs. The VA maintains the need for this capability. Therefore, this request seeks to acquire a brand name Trellix or equal software solution that meets or exceeds the VA's requirements as specified in Attachment A and detailed within this document.

The Period of Performance (PoP) shall be one 12-month base period, to begin on May 15, 2026 through May 14, 2027, four 12-month option periods, one optional task for base year professional services, and one optional task for additional licenses in each period of performance.

Please refer to and complete Attachment A, which describes the requirements for this effort.

1.1 SALIENT CHARACTERISTICS - SUBSCRIPTIONS

- Shall ensure all communication between agents and console are encrypted
- Shall utilize FIPS 140-3 compliant encryption for data-in-motion and data-at-rest by September 2026. (Provide either NIST certification number or proof of submission for FIPS 140-3 certification)
- Shall support Windows 11 Professional Operating System
- Centrally managed
- Agents are deployable with standard VA deployment methods using either BigFix or Configuration Manager (CM)
- Logging levels can be calibrated to control the types and volume of logged events on the agent and console
- Software updates shall be pushed from the server over the network
- Enables multiple analysts to connect to the management console and run jobs concurrently
- Utilizes a web-based user interface to the management console
- Simple to use query/reporting tool allowing easy data selection; reports generated via a GUI report wizard
- Ability to create and run summary and detailed reports as needed; export of reports shall be available in multiple formats (DOC*, PDF, XML)
- Event data across concurrently running agents are collected within a centralized, quarriable database
- Application Programming Interface (API) - driven integration with Security Information and Event Management (SIEM) tools
- Account management shall have ability to set and manage different user access levels
- Shall support Microsoft Active Directory (AD) integration

**Trellix Brand Name or Equal Compact Disc (CD) / Digital Versatile Disc (DVD)
Enterprise Encryption Software
VA-26- 00046223**

- Shall not unnecessarily impair normal system operations (e.g., patching, scanning, business software usage, information assurance tools/initiatives, secure host baseline, assured compliance assessment solution, etc.) nor shall it degrade managed system performance in any way, which may adversely impact on a system's primary business/mission functions.
- The Contractor shall provide software subscriptions and support services for the products listed and the quantities identified in the Table 1, Table 2 and Table 3 below.

Table 1: Schedule of Brand Name or Equivalent Software

Base Period May 15, 2026 - May 14, 2027				
Item #	Part Number	Description	Quantity	Unit
0001	TBD	CD/DVD Enterprise Encryption Software IAW PD 1.1 Product Service Code (PSC): DA10	1,000	EA
Option Period One May 15, 2027 - May 14, 2028				
1001	TBD	CD/DVD Enterprise Encryption Software IAW PD 1.1 PSC: DA10	1,000	EA
Option Period Two May 15, 2028 - May 14, 2029				
2001	TBD	CD/DVD Enterprise Encryption Software IAW PD 1.1 PSC: DA10	1,000	EA
Option Period Three May 15, 2029 - May 14, 2030				
3001	TBD	CD/DVD Enterprise Encryption Software IAW PD 1.1 PSC: DA10	1,000	EA
Option Period Four May 15, 2030 - May 14, 2031				
4001	TBD	CD/DVD Enterprise Encryption Software IAW PD 1.1 PSC: DA10	1,000	EA

**Trellix Brand Name or Equal Compact Disc (CD) / Digital Versatile Disc (DVD)
Enterprise Encryption Software
VA-26- 00046223**

1.2 PROFESSIONAL SERVICES (BASE PERIOD OPTIONAL TASK 1 – NTE 80 HOURS)

The Contractor shall provide consulting hours for professional services supporting the deployment, optimization, and management of security solutions.

The Contractor shall make these hours available for activities including, but not limited to:

- Proactive threat hunting and alert investigation
- On-site or remote consulting
- System optimization and health checks

Table 2: Professional Services

BASE PERIOD OPTIONAL TASK 1 – NTE 80 HOURS (HRS)				
These optional items may be exercised IAW FAR 52.217-7 Option for Increase Quantity – Separately Priced Line Item. These optional items can be exercised at any time and from time to time at any point during performance of this order up to the NTE amount over the life of the order. The PoP for all optional items shall not exceed 12 months and shall be co-termed to expire at the end of the performance period in which it is exercised. In no event shall the PoP of an optional line item extend the overall PoP. May 15, 2026 - May 14, 2027				
Item #	Part Number	Description	Quantity	Unit
0002	TBD	Professional Services (NTE 80 Hours) IAW PD 1.2	80	HRS

1.3 ADDITIONAL SUBSCRIPTIONS (OPTIONAL TASK 2)

As identified in the tables below, the Contractor shall provide VA with the ability to acquire one or more additional subscriptions during the period of performance of this effort, to include the Base Period and each Option Period. Any purchase of these optional subscriptions shall be prorated and co-term with the Period of Performance of the Base Period or Option Period in which they are purchased. (These subscriptions can be purchased at any quantity up to the NTE quantity at time of optional task exercise.)

Table 3: Brand Name or Equivalent Software Optional Quantities

Trellix Brand Name or Equal Compact Disc (CD) / Digital Versatile Disc (DVD)
Enterprise Encryption Software
VA-26- 00046223

BASE PERIOD OPTIONAL QUANTITIES – OPTIONAL TASK 2				
These optional items may be exercised IAW FAR 52.217-7 Option for Increase Quantity – Separately Priced Line Item. These optional items can be exercised at any time and from time to time at any point during performance of this order up to the NTE amount over the life of the order. The PoP for all optional items shall not exceed 12 months and shall be co-termed to expire at the end of the performance period in which it is exercised. In no event shall the PoP of an optional line item extend the overall PoP.				
Item #	Part Number	Description	Quantity	Unit
5001	TBD	CD/DVD Enterprise Encryption Software IAW PD 1.3	500	EA
OPTION PERIOD 1 OPTIONAL QUANTITIES – OPTIONAL TASK 2				
These optional items may be exercised IAW FAR 52.217-7 Option for Increase Quantity – Separately Priced Line Item. These optional items can be exercised at any time and from time to time at any point during performance of this order up to the NTE amount over the life of the order. The PoP for all optional items shall not exceed 12 months and shall be co-termed to expire at the end of the performance period in which it is exercised. In no event shall the PoP of an optional line item extend the overall PoP.				
Item #	Part Number	Description	Quantity	Unit
5002	TBD	CD/DVD Enterprise Encryption Software IAW PD 1.3	500	EA
OPTION PERIOD 2 OPTIONAL QUANTITIES – OPTIONAL TASK 2				
These optional items may be exercised IAW FAR 52.217-7 Option for Increase Quantity – Separately Priced Line Item. These optional items can be exercised at any time and from time to time at any point during performance of this order up to the NTE amount over the life of the order. The PoP for all optional items shall not exceed 12 months and shall be co-termed to expire at the end of the performance period in which it is exercised. In no event shall the PoP of an optional line item extend the overall PoP.				
Item #		Description	Quantity	Unit

**Trellix Brand Name or Equal Compact Disc (CD) / Digital Versatile Disc (DVD)
Enterprise Encryption Software
VA-26- 00046223**

	Part Number			
5003	TBD	CD/DVD Enterprise Encryption Software IAW PD 1.3	500	EA
OPTION PERIOD 3 OPTIONAL QUANTITIES – OPTIONAL TASK 2 These optional items may be exercised IAW FAR 52.217-7 Option for Increase Quantity – Separately Priced Line Item. These optional items can be exercised at any time and from time to time at any point during performance of this order up to the NTE amount over the life of the order. The PoP for all optional items shall not exceed 12 months and shall be co-termed to expire at the end of the performance period in which it is exercised. In no event shall the PoP of an optional line item extend the overall PoP.				
Item #	Part Number	Description	Quantity	Unit
5004	TBD	CD/DVD Enterprise Encryption Software IAW PD 1.3	500	EA
OPTION PERIOD 4 OPTIONAL QUANTITIES – OPTIONAL TASK 2 These optional items may be exercised IAW FAR 52.217-7 Option for Increase Quantity – Separately Priced Line Item. These optional items can be exercised at any time and from time to time at any point during performance of this order up to the NTE amount over the life of the order. The PoP for all optional items shall not exceed 12 months and shall be co-termed to expire at the end of the performance period in which it is exercised. In no event shall the PoP of an optional line item extend the overall PoP.				
Item #	Part Number	Description	Quantity	Unit
5005	TBD	CD/DVD Enterprise Encryption Software IAW PD 1.3	500	EA

1.4 SOFTWARE SUPPORT

The contractor shall provide technical support for all subscriptions purchased. All technical support shall be provided 24 hours a day, 7 days a week, 365 days a year, to

Trellix Brand Name or Equal Compact Disc (CD) / Digital Versatile Disc (DVD)
Enterprise Encryption Software
VA-26- 00046223

include access to online and phone support. All technical support shall include but not be limited to major product and technology releases, technical support, updates, fixes, security alerts, data fixes, and critical patch updates, upgrade scripts, tax, legal, and regulatory updates and certification with most existing third-party products/versions.

2.0 NOTICE OF THE FEDERAL ACCESSIBILITY LAW AFFECTING ALL INFORMATION AND COMMUNICATION TECHNOLOGY (ICT) PROCUREMENTS (SECTION 508)

On January 18, 2017, the Architectural and Transportation Barriers Compliance Board (Access Board) revised and updated, in a single rulemaking, standards for electronic and information technology developed, procured, maintained, or used by Federal agencies covered by Section 508 of the Rehabilitation Act of 1973, as well as our guidelines for telecommunications equipment and customer premises equipment covered by Section 255 of the Communications Act of 1934. The revisions and updates to the Section 508-based standards and Section 255-based guidelines are intended to ensure that information and communication technology (ICT) covered by the respective statutes is accessible to and usable by individuals with disabilities.

2.1 SECTION 508 – INFORMATION AND COMMUNICATION TECHNOLOGY (ICT) STANDARDS

The Section 508 standards established by the Access Board are incorporated into, and made part of all VA orders, solicitations and purchase orders developed to procure ICT. These standards are found in their entirety at: [Revised 508 Standards and 255 Guidelines \(access-board.gov\)](https://www.access-board.gov/section-508/). A single PDF file version of the Revised Section 508 Standards and 255 Guidelines will be supplied upon request or can be obtained from the Access Board website. Federal agencies must comply with the Rehabilitation Act of 1973, as amended.

The Contractor shall comply with “508 Chapter 2: Scoping Requirements” for all electronic ICT and content delivered under this contract. Specifically, as appropriate for the technology and its functionality, the Contractor shall comply with the technical standards marked here:

- ☒ E205 Electronic Content – (Accessibility Standard -WCAG 2.0 Level A and AA Guidelines)
- ☒ E204 Functional Performance Criteria
- ☐ E206 Hardware Requirements
- ☒ E207 Software Requirements
- ☒ E208 Support Documentation and Services Requirements

2.2 COMPATABILITY WITH ASSISTIVE TECHNOLOGY

Trellix Brand Name or Equal Compact Disc (CD) / Digital Versatile Disc (DVD)
Enterprise Encryption Software
VA-26- 00046223

The standards do not require installation of specific accessibility-related software or attachment of an assistive technology device. Section 508 requires that ICT be compatible with such software and devices so that ICT can be accessible to and usable by individuals using assistive technology, including but not limited to screen readers, screen magnifiers, and speech recognition software.

2.3 ACCEPTANCE AND ACCEPTANCE TESTING

Deliverables resulting from this solicitation will be accepted based in part on satisfaction of Section 508 Chapter 2: Scoping Requirements standards identified above.

The Government reserves the right to test for Section 508 Compliance before delivery. The Contractor shall be able to demonstrate Section 508 Compliance upon delivery.

3.0 INFORMATION TECHNOLOGY USING SUSTAINABLE PRODUCTS AND SERVICES

Not applicable.

4.0 SHIPMENT OF HARDWARE OR EQUIPMENT

Not applicable.

5.0 GENERAL REQUIREMENTS

5.1 VA TECHNICAL REFERENCE MODEL

The Contractor shall comply with the VA OIT Technical Reference Model (VA TRM). Compliance with the VA TRM is achieved by using only technologies and standards that are listed as approved for use in the VA TRM. The Contractor shall provide all necessary information requested by VA to ensure TRM approval is obtained prior to use on VA's network.

5.2 ZERO TRUST – VA CRITICAL SECURITY CONTROLS

VA has established minimum mandatory security requirements and requires that any network connected software system or service must meet the VA Critical Security Controls as outlined in the VA Memorandum, "VA Security Controls", <https://www.voa.va.gov/DocumentView.aspx?DocumentID=5010>. VA Critical Security Controls identify the minimum mandatory requirements that must be implemented across all VA enterprise infrastructure, cloud computing environments, information systems, networks, and specialized devices (medical devices/systems, special-purpose systems, and research scientific computing devices) that process, store, and/or transmit VA data. Effective July 1, 2025, the Contractor shall implement these VA Critical

Trellix Brand Name or Equal Compact Disc (CD) / Digital Versatile Disc (DVD)
Enterprise Encryption Software
VA-26- 00046223

Security Controls, within any network connected software system or service prior to being authorized for use in the VA. This functional requirement is not negotiable, and Plan of Action & Milestones (POAM) will not be accepted in the event these controls cannot be implemented for new systems. Critical Security Controls are intended to increase VA's security posture and provide security and privacy risk visibility into the VA network and is not a new requirement. The Contractor's failure to maintain these VA Critical Controls after implementation will result in VA discontinuing the use of the system.

5.3 SOCIAL SECURITY NUMBER (SSN) REDUCTION

The Contractor solution shall support the Social Security Number (SSN) Fraud Prevention Act (FPA) of 2017 which prohibits the inclusion of SSNs on any document sent by mail. The Contractor support shall also be performed in accordance with Section 240 of the Consolidated Appropriations Act (CAA) 2018, enacted March 23, 2018, which mandates VA to discontinue using SSNs to identify individuals in all VA information systems as the Primary Identifier. The Contractor shall ensure that any new IT solution discontinues the use of SSN as the Primary Identifier to replace the SSN with the Integrated Control Number (ICN) in all VA information systems for all individuals. The Contractor shall ensure that all Contractor delivered applications and systems integrate with the VA Master Person Index (MPI) for identity traits to include the use of the ICN as the Primary Identifier. The Contractor solution may only use a Social Security Number to identify an individual in an information system if and only if the use of such number is required to obtain information VA requires from an information system that is not under the jurisdiction of VA.

5.4 INTERNET PROTOCOL VERSION 6 (IPv6)

The Contractor solution shall support Internet Protocol Version 6 (IPv6) based upon the memo issued by the Office of Management and Budget (OMB) on November 19, 2020 (<https://www.whitehouse.gov/wp-content/uploads/2020/11/M-21-07.pdf>). IPv6 technology, in accordance with the USGv6 Program (<https://www.nist.gov/programs-projects/usgv6-program/usgv6-revision-1>), NIST Special Publication (SP) 500-267B Revision 1 "USGv6 Profile" (<https://doi.org/10.6028/NIST.SP.500-267Br1>), and NIST SP 800-119 "Guidelines for the Secure Deployment of IPv6" (<https://doi.org/10.6028/NIST.SP.800-119>), compliance shall be included in all IT infrastructures, application designs, application development, operational systems and sub-systems, and their integration. In addition to the above requirements, all devices shall support native IPv6 and dual stack (IPv6 / IPv4) connectivity without additional memory or other resources being provided by the Government, so that they can function in a mixed environment. All public/external facing servers and services (e.g. web, email, DNS, ISP services, etc.) shall support native IPv6 and dual stack (IPv6 /

**Trellix Brand Name or Equal Compact Disc (CD) / Digital Versatile Disc (DVD)
Enterprise Encryption Software
VA-26- 00046223**

IPv4) users and all internal infrastructure and applications shall communicate using native IPv6-Only and dual stack (IPv6 / IPv4) for all functionality and operations.

5.5 SOFTWARE AND LICENSING REQUIREMENTS

The Contractor shall be responsible for the provision of all software licenses and any associated licensing maintenance required for any development, delivery, integration, operation, and/or maintenance associated with its proposed application(s), software products, software solution, and/or system including, but not limited to, any and all application(s), software and/or software products that comprise, are a part of, or integrate with the Contractor's proposed application(s), software products, software solution, and/or system for the life of any resulting contract.

5.6 TRUSTED INTERNET CONNECTION (TIC)

The Contractor solution shall meet the requirements outlined in Office of Management and Budget Memorandum M-19-26, "Update to the Trusted Internet Connections (TIC) Initiative" (<https://www.whitehouse.gov/wp-content/uploads/2019/09/M-19-26.pdf>), VA Directive 6513 "Secure External Connections", and shall comply with the TIC 3.0 Core Guidance Documents, including all Volumes and TIC Use Cases, found at the Cybersecurity & Infrastructure Security Agency (CISA) (<https://www.cisa.gov/publication/tic-30-core-guidance-documents>.)

6.0 POINTS OF CONTACT

VA Program Manager:

Name: Kirk Hastings
Address:
Voice: 724-496-2301
Email: Kirk.Hastings@va.gov

Contracting Officer's Representative:

Name: N/A
Address:
Voice:
Email: N/A

Contracting Officer:

Name: Evan Schlisserman
Address:
Voice: 848-377-5248
Email: Evan.Schlisserman@va.gov

**Trellix Brand Name or Equal Compact Disc (CD) / Digital Versatile Disc (DVD)
Enterprise Encryption Software
VA-26- 00046223**

Contract Specialist:

Name: Julia Renna

Address:

Voice: 848-377-5298

Email: Julia.Renna@va.gov

DRAFT

Trellix Brand Name or Equal Compact Disc (CD) / Digital Versatile Disc (DVD)
Enterprise Encryption Software
VA-26- 00046223

**ADDENDUM B – VA INFORMATION AND INFORMATION SYSTEM SECURITY/
PRIVACY LANGUAGE**

NOTE: In the event of a conflict, VAAR Security Clauses take precedence over the language in this Addendum B.

APPLICABLE SECTIONS FROM: *VA NOTICE 24-12, APRIL 22, 2024, UPDATE TO VA HANDBOOK 6500.6, CONTRACT SECURITY, APPENDIX C VA INFORMATION AND INFORMATION SYSTEM SECURITY/PRIVACY LANGUAGE, FOR INCLUSION INTO CONTRACTS, AS APPROPRIATE*

B1. GENERAL

This entire section applies to all acquisitions requiring any Information Security and Privacy language. Contractors, contractor personnel, Subcontractors and subcontractor personnel will be subject to the same federal laws, regulations, standards, VA directives and handbooks, as VA personnel regarding information and information system security and privacy.

B2. VA INFORMATION CUSTODIAL LANGUAGE

- a. The Government shall receive unlimited rights to data/intellectual property first produced and delivered in the performance of this contract or order (hereinafter “contract”) unless expressly stated otherwise in this contract. This includes all rights to source code and all documentation created in support thereof. The primary clause used to define Government and Contractor data rights is FAR 52.227-14 Rights in Data – General. The primary clause used to define computer software license (not data/intellectual property first produced under this Contractor or order) is FAR 52.227-19, Commercial Computer Software License.
- b. Information made available to the Contractor by VA for the performance or administration of this contract will be used only for the purposes specified in the service agreement, SOW, PWS, PD, and/or contract. The Contractor shall not use VA information in any other manner without prior written approval from a VA Contracting Officer (CO). The primary clause used to define Government and Contractor data rights is FAR 52.227-14 Rights in Data – General.
- c. VA information will not be co-mingled with any other data on the Contractor’s information systems or media storage systems. The Contractor shall ensure compliance with Federal and VA requirements related to data protection, data encryption, physical data segregation, logical data segregation, classification requirements and media sanitization.
- d. VA reserves the right to conduct scheduled or unscheduled audits, assessments, or investigations of Contractor Information Technology (IT) resources to ensure

Trellix Brand Name or Equal Compact Disc (CD) / Digital Versatile Disc (DVD)
Enterprise Encryption Software
VA-26- 00046223

information security is compliant with Federal and VA requirements. The Contractor shall provide all necessary access to records (including electronic and documentary materials related to the contracts and subcontracts) and support (including access to Contractor and Subcontractor staff associated with the contract) to VA, VA's Office Inspector General (OIG), and/or Government Accountability Office (GAO) staff during periodic control assessments, audits, or investigations.

- e. The Contractor may only use VA information within the terms of the contract and applicable Federal law, regulations, and VA policies. If new Federal information security laws, regulations or VA policies become applicable after execution of the contract, the parties agree to negotiate contract modification and adjustment necessary to implement the new laws, regulations, and/or policies.
- f. The Contractor shall not make copies of VA information except as specifically authorized and necessary to perform the terms of the contract. If copies are made for restoration purposes, after the restoration is complete, the copies shall be destroyed in accordance with VA Directive 6500, VA Cybersecurity Program and VA Information Security Knowledge Service.
- g. If a Veterans Health Administration (VHA) contract is terminated for default or cause with a business associate, the related local Business Associate Agreement (BAA) shall also be terminated and actions taken in accordance with VHA Directive 1605.05, Business Associate Agreements. If there is an executed national BAA associated with the contract, VA will determine what actions are appropriate and notify the contractor.
- h. The Contractor shall store and transmit VA sensitive information in an encrypted form, using VA-approved encryption tools which are, at a minimum, Federal Information Processing Standards (FIPS) 140-2, Security Requirements for Cryptographic Modules (or its successor) validated and in conformance with VA Information Security Knowledge Service requirements. The Contractor shall transmit VA sensitive information using VA approved Transport Layer Security (TLS) configured with FIPS based cipher suites in conformance with National Institute of Standards and Technology (NIST) 800-52, Guidelines for the Selection, Configuration and Use of Transport Layer Security (TLS) Implementations.
- i. The Contractor's firewall and web services security controls, as applicable, shall meet or exceed VA's minimum requirements.
- j. Except for uses and disclosures of VA information authorized by this contract for performance of the contract, the Contractor may use and disclose VA information only in two situations: (i) in response to a qualifying order of a court of competent jurisdiction after notification to VA CO (ii) with written approval from the VA CO.

Trellix Brand Name or Equal Compact Disc (CD) / Digital Versatile Disc (DVD)
Enterprise Encryption Software
VA-26- 00046223

The Contractor shall refer all requests for, demands for production of or inquiries about, VA information and information systems to the VA CO for response.

- k. Notwithstanding the provision above, the Contractor shall not release VA records protected by Title 38 U.S.C. § 5705, Confidentiality of medical quality-assurance records and/or Title 38 U.S.C. § 7332, Confidentiality of certain medical records pertaining to drug addiction, sickle cell anemia, alcoholism or alcohol abuse or infection with Human Immunodeficiency Virus (HIV). If the Contractor is in receipt of a court order or other requests for the above-mentioned information, the Contractor shall immediately refer such court order or other requests to the VA CO for response.
- l. Information made available to the Contractor by VA for the performance or administration of this contract or information developed by the Contractor in performance or administration of the contract will be protected and secured in accordance with VA Directive 6500 and Identity and Access Management (IAM) Security processes specified in the VA Information Security Knowledge Service.
- m. Any data destruction done on behalf of VA by a Contractor shall be done in accordance with National Archives and Records Administration (NARA) requirements as outlined in VA Directive 6300, Records and Information Management, VA Handbook 6300.1, Records Management Procedures, and applicable VA Records Control Schedules.
- n. The Contractor shall provide its plan for destruction of all VA data in its possession according to VA Directive 6500 and NIST 800-88, Guidelines for Media Sanitization prior to termination or completion of this contract. If directed by the COR/CO, the Contractor shall return all Federal Records to VA for disposition.
- o. Any media, such as paper, magnetic tape, magnetic disks, solid state devices or optical discs that is used to store, process, or access VA information that cannot be destroyed shall be returned to VA. The Contractor shall hold the appropriate material until otherwise directed by the Contracting Officer's Representative (COR) or CO. Items shall be returned securely via VA-approved methods. VA sensitive information must be transmitted utilizing VA-approved encryption tools which are validated under FIPS 140-2 (or its successor) and NIST 800-52. If mailed, the Contractor shall send via a trackable method (USPS, UPS, FedEx, etc.) and immediately provide the COR/CO with the tracking information. Self-certification by the Contractor that the data destruction requirements above have been met shall be sent to the COR/CO within 30 business days of termination of the contract.
- p. All electronic storage media (hard drives, optical disks, CDs, back-up tapes, etc.) used to store, process or access VA information will not be returned to the

Trellix Brand Name or Equal Compact Disc (CD) / Digital Versatile Disc (DVD)
Enterprise Encryption Software
VA-26- 00046223

Contractor at the end of lease, loan, or trade-in. Exceptions to this paragraph will only be granted with the written approval of the VA CO.

B3. SECURITY INCIDENT INVESTIGATION

- b. The Contractor, Subcontractor, their employees, or business associates shall immediately (within one hour) report suspected security / privacy incidents to the VA OIT's Enterprise Service Desk (ESD) by calling (855) 673-4357 (TTY: 711). The ESD is OIT's 24/7/365 single point of contact for IT-related issues. After reporting to the ESD, the Contractor, Subcontractor, their employees, or business associates shall, within one hour, provide the COR/CO the incident number received from the ESD.
- c. To the extent known by the Contractor/Subcontractor, the Contractor/Subcontractor's notice to VA shall identify the information involved and the circumstances surrounding the incident, including the following:
 - (1) The date and time (or approximation of) the Security Incident occurred.
 - (2) The names of individuals involved (when applicable).
 - (3) The physical and logical (if applicable) location of the incident.
 - (4) Why the Security Incident took place (i.e., catalyst for the failure).
 - (5) The amount of data belonging to VA believed to have been compromised.
 - (6) The remediation measures the Contractor is taking to ensure no future incidents of a similar nature.
- d. After the Contractor has provided the initial detailed incident summary to VA, they will continue to provide written updates on any new and relevant circumstances or facts they discover. The Contractor, Subcontractor, and their employees shall fully cooperate with VA or third-party entity performing an independent risk analysis on behalf of VA. Failure to cooperate may be deemed a material breach and grounds for contract termination.
- e. VA IT Contractors shall follow VA Handbook 6500, Risk Management Framework for VA Information Systems VA Information Security Program, and VA Information Security Knowledge Service guidance for implementing an Incident Response Plan or integrating with an existing VA implementation.
- f. In instances of theft or break-in or other criminal activity, the Contractor/Subcontractor must concurrently report the incident to the appropriate law enforcement entity (or entities) of jurisdiction, including the VA OIG, and the VA Office of Security and Law Enforcement. The Contractor, its employees, and

Trellix Brand Name or Equal Compact Disc (CD) / Digital Versatile Disc (DVD)
Enterprise Encryption Software
VA-26- 00046223

its Subcontractors and their employees shall cooperate with VA and any law enforcement authority responsible for the investigation and prosecution of any possible criminal law violation(s) associated with any incident. The Contractor/Subcontractor shall cooperate with VA in any civil litigation to recover VA information, obtain monetary or other compensation from a third party for damages arising from any incident, or obtain injunctive relief against any third party arising from, or related to, the incident.

- g. The Contractor shall comply with VA Handbook 6500.2, Management of Breaches Involving Sensitive Personal Information, which establishes the breach management policies and assigns responsibilities for the oversight, management and reporting procedures associated with managing of breaches.
- h. With respect to unsecured Protected Health Information (PHI), the Contractor is deemed to have discovered a data breach when the Contractor knew or should have known of breach of such information. When a business associate is part of VHA contract, notification to the covered entity (VHA) shall be made in accordance with the executed BAA.
- i. If the Contractor or any of its agents fails to protect VA sensitive personal information or otherwise engages in conduct which results in a data breach involving any VA sensitive personal information the Contractor/Subcontractor processes or maintains under the contract; the Contractor shall pay liquidated damages to the VA as set forth in clause [852.211-76, Liquidated Damages—Reimbursement for Data Breach Costs](#).

B4. INFORMATION SYSTEM DESIGN AND DEVELOPMENT

- a. Information systems designed or developed on behalf of VA at non-VA facilities shall comply with all applicable Federal law, regulations, and VA policies. This includes standards for the protection of electronic Protected Health Information (PHI), outlined in 45 C.F.R. Part 164, Subpart C and information and system security categorization level designations in accordance with FIPS 199, Standards for Security Categorization of Federal Information and Information Systems and FIPS 200, Minimum Security Requirements for Federal Information Systems. Baseline security controls shall be implemented commensurate with the FIPS 199 system security categorization (reference VA Handbook 6500 and VA Trusted Internet Connections (TIC) Architecture).
- b. Contracted new developments require creation, testing, evaluation, and authorization in compliance with VA Assessment and Authorization (A&A) processes in VA Handbook 6500 and VA Information Security Knowledge Service to obtain an Authority to Operate (ATO). VA Directive 6517, Risk Management Framework for Cloud Computing Services, provides the security and privacy requirements for cloud environments.

Trellix Brand Name or Equal Compact Disc (CD) / Digital Versatile Disc (DVD)
Enterprise Encryption Software
VA-26- 00046223

- c. VA IT Contractors, Subcontractors and third-party service providers shall address and/or integrate applicable VA Handbook 6500, VA Handbook 6517, Risk Management Framework for Cloud Computing Services and Information Security Knowledge Service specifications in delivered IT systems/solutions, products and/or services. If systems/solutions, products and/or services do not directly match VA security requirements, the Contractor shall work through the COR/CO to identify the VA organization responsible for governance or resolution. Contractors shall comply with FAR 39.1, specifically the prohibitions referenced.
- d. The Contractor (including producers and resellers) shall comply with Office of Management and Budget (OMB) M-22-18 and M-23-16 when using third-party software on VA information systems or otherwise affecting the VA information. This includes new software purchases and software renewals for software developed or modified by major version change after the issuance date of M-22-18 (September 14, 2022). The term "software" includes firmware, operating systems, applications and application services (e.g., cloud-based software), as well as products containing software. The Contractor shall provide a self-attestation that secure software development practices are utilized as outlined by Executive Order (EO) 14028 and NIST Guidance. A third-party assessment provided by either a certified Federal Risk and Authorization Management Program (FedRAMP) Third Party Assessor Organization (3PAO) or one approved by the agency will be acceptable in lieu of a software producer's self-attestation.
- e. The Contractor shall ensure all delivered applications, systems and information systems are compliant with Homeland Security Presidential Directive (HSPD) 12 and VA Identity and Access management (IAM) enterprise identity management requirements as set forth in OMB M-19-17, M-05-24, FIPS 201-3, Personal Identity Verification (PIV) of Federal Employees and Contractors (or its successor), M-21-31 and supporting NIST guidance. This applies to Commercial Off-The-Shelf (COTS) product(s) that the Contractor did not develop, all software configurations and all customizations.
- f. The Contractor shall ensure all Contractor delivered applications and systems provide user authentication services compliant with VA Handbook 6500, VA Information Security Knowledge Service, IAM enterprise requirements and NIST 800-63, Digital Identity Guidelines, for direct, assertion-based authentication and/or trust-based authentication, as determined by the design and integration patterns. Direct authentication at a minimum must include Public Key Infrastructure (PKI) based authentication supportive of PIV and/or Common Access Card (CAC), as determined by the business need and compliance with VA Information Security Knowledge Service specifications.

Trellix Brand Name or Equal Compact Disc (CD) / Digital Versatile Disc (DVD)
Enterprise Encryption Software
VA-26- 00046223

- g. The Contractor shall use VA authorized technical security baseline configurations and certify to the COR that applications are fully functional and operate correctly as intended on systems in compliance with VA baselines prior to acceptance or connection into an authorized VA computing environment. If the Defense Information Systems Agency (DISA) has created a Security Technical Implementation Guide (STIG) for the technology, the Contractor may configure to comply with that STIG. If VA determines a new or updated VA configuration baseline needs to be created, the Contractor shall provide required technical support to develop the configuration settings. FAR 39.1 requires the population of operating systems and applications includes all listed on the NIST National Checklist Program Checklist Repository,
- h. The standard installation, operation, maintenance, updating and patching of software shall not alter the configuration settings from VA approved baseline configuration. Software developed for VA must be compatible with VA enterprise installer services and install to the default "program files" directory with silently install and uninstall. The Contractor shall perform testing of all updates and patching prior to implementation on VA systems.
- i. Applications designed for normal end users will run in the standard user context without elevated system administration privileges.
- j. The Contractor-delivered solutions shall reside on VA approved operating systems. Exceptions to this will only be granted with the written approval of the COR/CO.
- k. The Contractor shall design, develop, and implement security and privacy controls in accordance with the provisions of VA security system development life cycle outlined in NIST 800-37, Risk Management Framework for Information Systems and Organizations: A System Life Cycle Approach for Security and Privacy, VA Directive and Handbook 6500, and VA Handbook 6517.
- l. The Contractor shall comply with the Privacy Act of 1974 (the Act), FAR 52.224-2 Privacy Act, and VA rules and regulations issued under the Act in the design, development, or operation of any system of records on individuals to accomplish a VA function.
- m. The Contractor shall ensure the security of all procured or developed information systems, systems, major applications, minor applications, enclaves and platform information technologies, including their subcomponents (hereinafter referred to as "Information Systems") throughout the life of this contract and any extension, warranty, or maintenance periods. This includes security configurations, workarounds, patches, hotfixes, upgrades, replacements and any physical components which may be necessary to remediate all security vulnerabilities published or known to the Contractor anywhere in the information systems

Trellix Brand Name or Equal Compact Disc (CD) / Digital Versatile Disc (DVD)
Enterprise Encryption Software
VA-26- 00046223

(including systems, operating systems, products, hardware, software, applications and firmware). The Contractor shall ensure security fixes do not negatively impact the Information Systems.

- n. When the Contractor is responsible for operations or maintenance of the systems, the Contractor shall apply the security fixes within the timeframe specified by the associated controls on the VA Information Security Knowledge Service. When security fixes involve installing third party patches (such as Microsoft OS patches or Adobe Acrobat), the Contractor shall provide written notice to the VA COR/CO that the patch has been validated as to not affecting the Systems within 10 business days.

B5. INFORMATION SYSTEM HOSTING, OPERATION, MAINTENANCE OR USE

- a. The Contractor shall comply with all Federal laws, regulations, and VA policies for Information systems (cloud and non-cloud) that are hosted, operated, maintained, or used on behalf of VA at non-VA facilities. Security controls for collecting, processing, transmitting, and storing of VA sensitive information, must be in place. The controls will be tested by VA or a VA sanctioned 3PAO and approved by VA prior to hosting, operation, maintenance or use of the information system or systems by or on behalf of VA. This includes conducting compliance risk assessments, security architecture analysis, routine vulnerability scanning, system patching, change management procedures and the completion of an acceptable contingency plan for each system. The Contractor's security control procedures shall be the same as procedures used to secure VA-operated information systems.
- b. Outsourcing (Contractor facility, equipment, or staff) of systems or network operations, telecommunications services or other managed services require Assessment and Authorization (A&A) of the Contractor's systems in accordance with VA Handbook 6500 as specified in VA Information Security Knowledge Service. Major changes to the A&A package may require reviewing and updating all the documentation associated with the change. The Contractor's cloud computing systems shall comply with FedRAMP and VA Directive 6517 requirements.
- c. The Contractor shall return all electronic storage media (hard drives, optical disks, CDs, back-up tapes, etc.) on non-VA leased or non-VA owned IT equipment used to store, process or access VA information to VA in accordance with A&A package requirements. This applies when the contract is terminated or completed and prior to disposal of media. The Contractor shall provide its plan for destruction of all VA data in its possession according to VA Information Security Knowledge Service requirements and NIST 800-88. The Contractor shall send a self-certification that the data destruction requirements above have been met to the COR/CO within 30 business days of termination of the contract.

Trellix Brand Name or Equal Compact Disc (CD) / Digital Versatile Disc (DVD)
Enterprise Encryption Software
VA-26- 00046223

- d. All external internet connections to VA network involving VA information must be in accordance with VA Trusted Internet Connection (TIC) Reference Architecture and VA Directive and Handbook 6513, Secure External Connections and reviewed and approved by VA prior to implementation. Government-owned Contractor-operated systems, third party or business partner networks require a Memorandum of Understanding (MOU) and Interconnection Security Agreements (ISA).
- e. Contractor procedures shall be subject to periodic, announced, or unannounced assessments by VA officials, the OIG or a 3PAO. The physical security aspects associated with Contractor activities are also subject to such assessments. The Contractor shall report, in writing, any deficiencies noted during the above assessment to the VA COR/CO. The Contractor shall use VA's defined processes to document planned remedial actions that address identified deficiencies in information security policies, procedures, and practices. The Contractor shall correct security deficiencies within the timeframes specified in the VA Information Security Knowledge Service.
- f. All major information system changes which occur in the production environment shall be reviewed by the VA to determine the impact on privacy and security of the system. Based on the review results, updates to the Authority to Operate (ATO) documentation and parameters may be required to remain in compliance with VA Handbook 6500 and VA Information Security Knowledge Service requirements.
- g. The Contractor shall conduct an annual privacy and security self-assessment on all information systems and outsourced services as required. Copies of the assessment shall be provided to the COR/CO. The VA/Government reserves the right to conduct assessment using government personnel or a third-party if deemed necessary. The Contractor shall correct or mitigate any weaknesses discovered during the assessment.
- h. VA prohibits the installation and use of personally owned or Contractor-owned equipment or software on VA information systems. If non-VA owned equipment must be used to fulfill the requirements of a contract, it must be stated in the service agreement, SOW, PWS, PD or contract. All security controls required for government furnished equipment must be utilized in VA approved Other Equipment (OE). Configuration changes to the Contractor OE, must be funded by the owner of the equipment. All remote systems must use a VA-approved antivirus software and a personal (host-based or enclave based) firewall with a VA-approved configuration. The Contractor shall ensure software on OE is kept current with all critical updates and patches. Owners of approved OE are responsible for providing and maintaining the anti-virus software and the firewall

Trellix Brand Name or Equal Compact Disc (CD) / Digital Versatile Disc (DVD)
Enterprise Encryption Software
VA-26- 00046223

on the non-VA owned OE. Approved Contractor OE will be subject to technical inspection at any time.

- i. The Contractor shall notify the COR/CO within one hour of disclosure or successful exploits of any vulnerability which can compromise the confidentiality, integrity, or availability of the information systems. The system or effected component(s) need(s) to be isolated from the network. A forensic analysis needs to be conducted jointly with VA. Such issues will be remediated as quickly as practicable, but in no event longer than the timeframe specified by VA Information Security Knowledge Service. If sensitive personal information is compromised reference VA Handbook 6500.2 and Section 5, Security Incident Investigation.
- j. For cases wherein the Contractor discovers material defects or vulnerabilities impacting products and services they provide to VA, the Contractor shall develop and implement policies and procedures for disclosure to VA, as well as remediation. The Contractor shall, within 30 business days of discovery, document a summary of these vulnerabilities or defects. The documentation will include a description of the potential impact of each vulnerability and material defect, compensating security controls, mitigations, recommended corrective actions, root cause analysis and/or workarounds (i.e., monitoring). Should there exist any backdoors in the products or services they provide to VA (referring to methods for bypassing computer authentication), the Contractor shall provide the VA CO/CO written assurance they have permanently remediated these backdoors.
- k. All other vulnerabilities, including those discovered through routine scans or other assessments, will be remediated based on risk, in accordance with the remediation timelines specified by the VA Information Security Knowledge Service and/or the applicable timeframe mandated by Cybersecurity & Infrastructure Security Agency (CISA) Binding Operational Directive (BOD) 22-01 and BOD 19-02 for Internet-accessible systems. Exceptions to this paragraph will only be granted with the approval of the COR/CO.

B6. SECURITY AND PRIVACY CONTROLS COMPLIANCE TESTING, ASSESSMENT AND AUDITING

- a. Should VA request it, the Contractor shall provide a copy of their (corporation's, sole proprietorship's, partnership's, limited liability company (LLC), or other business structure entity's) policies, procedures, evidence and independent report summaries related to specified cybersecurity frameworks (International Organization for Standardization (ISO), NIST Cybersecurity Framework (CSF), etc.). VA or its third-party/partner designee (if applicable) are further entitled to perform their own audits and security/penetration tests of the Contractor's IT or systems and controls, to ascertain whether the Contractor is complying with the

Trellix Brand Name or Equal Compact Disc (CD) / Digital Versatile Disc (DVD)
Enterprise Encryption Software
VA-26- 00046223

information security, network or system requirements mandated in the agreement between VA and the Contractor.

- b. Any audits or tests of the Contractor or third-party designees/partner VA elects to carry out will commence within 30 business days of VA notification. Such audits, tests and assessments may include the following: (a): security/penetration tests which both sides agree will not unduly impact Contractor operations; (b): interviews with pertinent stakeholders and practitioners; (c): document review; and (d): technical inspections of networks and systems the Contractor uses to destroy, maintain, receive, retain, or use VA information.
- c. As part of these audits, tests and assessments, the Contractor shall provide all information requested by VA. This information includes, but is not limited to, the following: equipment lists, network or infrastructure diagrams, relevant policy documents, system logs or details on information systems accessing, transporting, or processing VA data.
- d. The Contractor and at its own expense, shall comply with any recommendations resulting from VA audits, inspections and tests. VA further retains the right to view any related security reports the Contractor has generated as part of its own security assessment. The Contractor shall also notify VA of the existence of any such security reports or other related assessments, upon completion and validation.
- e. VA appointed auditors or other government agency partners may be granted access to such documentation on a need-to-know basis and coordinated through the COR/CO. The Contractor shall comply with recommendations which result from these regulatory assessments on the part of VA regulators and associated government agency partners.

B7. PRODUCT INTEGRITY, AUTHENTICITY, PROVENANCE, ANTI-COUNTERFEIT AND ANTI-TAMPERING

- a. The Contractor shall comply with Code of Federal Regulations (CFR) Title 15 Part 7, "Securing the Information and Communications Technology and Services (ICTS) Supply Chain", which prohibits ICTS Transactions from foreign adversaries. ICTS Transactions are defined as any acquisition, importation, transfer, installation, dealing in or use of any information and communications technology or service, including ongoing activities, such as managed services, data transmission, software updates, repairs or the platforming or data hosting of applications for consumer download.
- b. When contracting terms require the Contractor to procure equipment, the Contractor shall purchase or acquire the equipment from an Original Equipment Manufacturer (OEM) or an authorized reseller of the OEM. The Contractor shall

Trellix Brand Name or Equal Compact Disc (CD) / Digital Versatile Disc (DVD)
Enterprise Encryption Software
VA-26- 00046223

attest that equipment procured from an OEM or authorized reseller or distributor are authentic. If procurement is unavailable from an OEM or authorized reseller, the Contractor shall submit in writing, details of the circumstances prohibiting this from happening and procure a product waiver from the VA COR/CO.

- c. All Contractors shall establish, implement, and provide documentation for risk management practices for supply chain delivery of hardware, software (to include patches) and firmware provided under this agreement. Documentation will include chain of custody practices, inventory management program, information protection practices, integrity management program for sub-supplier provided components, and replacement parts requests. The Contractor shall make spare parts available. All Contractor(s) shall specify how digital delivery for procured products, including patches, will be validated and monitored to ensure consistent delivery. The Contractor shall apply encryption technology to protect procured products throughout the delivery process.
- d. If a Contractor provides software or patches to VA, the Contractor shall publish or provide a hash conforming to the FIPS Security Requirements for Cryptographic Modules (FIPS 140-2 or successor).
- e. The Contractor shall provide a software bill of materials (SBOM) for procured (to include licensed products) and consist of a list of components and associated metadata which make up the product. SBOMs must be generated in one of the data formats defined in the National Telecommunications and Information Administration (NTIA) report "The Minimum Elements for a Software Bill of Materials (SBOM)."
- f. Contractors shall use or arrange for the use of trusted channels to ship procured products, such as U.S. registered mail and/or tamper-evident packaging for physical deliveries.
- g. Throughout the delivery process, the Contractor shall demonstrate a capability for detecting unauthorized access (tampering).
- h. The Contractor shall demonstrate chain-of-custody documentation for procured products and require tamper-evident packaging for the delivery of this hardware.

B8. VIRUSES, FIRMWARE, AND MALWARE

- a. The Contractor shall execute due diligence to ensure all provided software and patches, including third-party patches, are free of viruses and/or malware before releasing them to or installing them on VA information systems.
- b. The Contractor warrants it has no knowledge of and did not insert, any malicious virus and/or malware code into any software or patches provided to VA which

Trellix Brand Name or Equal Compact Disc (CD) / Digital Versatile Disc (DVD)
Enterprise Encryption Software
VA-26- 00046223

could potentially harm or disrupt VA information systems. The Contractor shall use due diligence, if supplying third-party software or patches, to ensure the third-party has not inserted any malicious code and/or virus which could damage or disrupt VA information systems.

- c. The Contractor shall provide or arrange for the provision of technical justification as to why any “false positive” hit has taken place to ensure their code’s supply chain has not been compromised. Justification may be required, but is not limited to, when install files, scripts, firmware, or other Contractor-delivered software solutions (including third-party install files, scripts, firmware, or other software) are flagged as malicious, infected, or suspicious by an anti-virus vendor.
- d. The Contractor shall not upload (intentionally or negligently) any virus, worm, malware or any harmful or malicious content, component and/or corrupted data/source code (hereinafter “virus or other malware”) onto VA computer and information systems and/or networks. If introduced (and this clause is violated), upon written request from the VA CO, the Contractor shall:
 - (1) Take all necessary action to correct the incident, to include any and all assistance to VA to eliminate the virus or other malware throughout VA’s information networks, computer systems and information systems; and
 - (2) Use commercially reasonable efforts to restore operational efficiency and remediate damages due to data loss or data integrity damage, if the virus or other malware causes a loss of operational efficiency, data loss, or damage to data integrity.

B9. CRYPTOGRAPHIC REQUIREMENT

- a. The Contractor shall document how the cryptographic system supporting the Contractor’s products and/or services protect the confidentiality, data integrity, authentication and non-repudiation of devices and data flows in the underlying system.
- b. The Contractor shall use only approved cryptographic methods as defined in FIPS 140-2 (or its successor) and NIST 800-52 standards when enabling encryption on its products.
- c. The Contractor shall provide or arrange for the provision of an automated remote key-establishment method which protects the confidentiality and integrity of the cryptographic keys.
- d. The Contractor shall ensure emergency re-keying of all devices can be remotely performed within 30 business days.

Trellix Brand Name or Equal Compact Disc (CD) / Digital Versatile Disc (DVD)
Enterprise Encryption Software
VA-26- 00046223

- e. The Contractor shall provide or arrange for the provision of a method for updating cryptographic primitives or algorithms.

B10. PATCHING GOVERNANCE

- a. The Contractor shall provide documentation detailing the patch management, vulnerability management, mitigation and update processes (to include third-party) prior to the connection of electronic devices, assets or equipment to VA's assets. This documentation will include information regarding the following:
 - (1) The resources and technical capabilities to sustain the program or process (e.g., how the integrity of a patch is validated by VA); and.
 - (2) The approach and capability to remediate newly reported zero-day vulnerabilities for Contractor products.
- b. The Contractor shall verify and provide documentation all procured products (including third-party applications, hardware, software, operating systems, and firmware) have appropriate updates and patches installed prior to delivery to VA.
- c. The Contractor shall provide or arrange the provision of appropriate software and firmware updates to remediate newly discovered vulnerabilities or weaknesses for their products and services within 30 days of discovery. Updates to remediate critical or emergent vulnerabilities will be provided within seven business days of discovery. If updates cannot be made available by Contractor within these time periods, the Contractor shall submit mitigations, methods of exploit detection and/or workarounds to the COR/CO prior to the above deadlines.
- d. The Contractor shall provide or arrange for the provision of appropriate hardware, software and/or firmware updates, when those products, including open-source software, are provided to the VA, to remediate newly discovered vulnerabilities or weaknesses. Remediations of products or services provided to the VA's system environment must be provided within 30 business days of availability from the original supplier and/or patching source. Updates to remediate critical vulnerabilities applicable to the Contractor's use of the third-party product in its system environment will be provided within seven business days of availability from the original supplier and/or patching source. If applicable third-party updates cannot be integrated, tested and made available by Contractor within these time periods, mitigations and/or workarounds will be provided to the COR/CO before the above deadlines.

B11. DATA CENTER PROVISIONS

Trellix Brand Name or Equal Compact Disc (CD) / Digital Versatile Disc (DVD)
Enterprise Encryption Software
VA-26- 00046223

- a. The Contractor shall ensure the VA network is accessed by in accordance with VA Directive 6500 and IAM security processes specified in the VA Information Security Knowledge Service.
- b. The Contractor shall ensure network infrastructure and data availability in accordance with VA information system business continuity procedures specified in the VA Information Security Knowledge Service.
- c. The Contractor shall ensure any connections to the internet or other external networks for information systems occur through managed interfaces utilizing VA approved boundary protection devices (e.g., internet proxies, gateways, routers, firewalls, guards or encrypted tunnels).
- d. The Contractor shall encrypt all traffic across the segment of the Wide Area Network (WAN) it manages and no unencrypted Out of Band (OOB) Internet Protocol (IP) traffic will traverse the network.
- e. The Contractor shall ensure tunnel endpoints are routable addresses at each VA operating site.
- f. The Contractor shall secure access from Local Area Networks (LANs) at co-located sites in accordance with VA TIC Reference Architecture, VA Directive and Handbook 6513, and MOU/ISA process specified in the VA Information Security Knowledge Service.